

X Money Recon Notes

April 19, 2026 · Personal Security Research · NOT a confirmed vulnerability report

Scope

- p.money.x.com
- api.money.x.com
- webhooks.money.x.com
- admin.money.x.com

Summary Assessment

CONCLUSION	No actionable security issue confirmed at this time.
CLASSIFICATION	Reconnaissance only · Exposed but minimal health check · Properly protected debug surfaces

- ✓ p.money.x.com/healthz returns 200 OK with body **OK**
- ✓ /debug/requests and /debug/events exist but return **401 Unauthorized**
- ✓ Common sensitive/debug/config paths return **404**
- ✓ api.money.x.com and webhooks.money.x.com are blocked behind Cloudflare with **403**
- ✓ Traversal and encoding attempts did not succeed
- ✓ No CORS misconfiguration observed in captured output
- ✓ admin.money.x.com IP (199.16.156.66) appears Cloudflare-owned — port 443 filtered

Evidence Log

[01] Initial Endpoint Checks

Command

```
for url in \  
"https://p.money.x.com/debug/pprof/" \  
"https://p.money.x.com/healthz" \  
"https://p.money.x.com/debug/vars" \  
"https://p.money.x.com/config.json" \  
"https://p.money.x.com/.env" \  
"https://api.money.x.com/v1/health" \  
"https://webhooks.money.x.com/v2/config"; do  
curl -kI -H "Origin: https://evil.com" "$url" 2>&1 \  
done
```

```
| grep -E "HTTP/|access-control|location|server"

dig +short CNAME p.money.x.com

done
```

Output

```
[+] https://p.money.x.com/debug/pprof/ HTTP/2 404

[+] https://p.money.x.com/healthz HTTP/2 200

[+] https://p.money.x.com/debug/vars HTTP/2 404

[+] https://p.money.x.com/config.json HTTP/2 404

[+] https://p.money.x.com/.env HTTP/2 404

[+] https://api.money.x.com/v1/health HTTP/2 403 server: cloudflare

[+] https://webhooks.money.x.com/v2/config HTTP/2 403 server: cloudflare

[DNS] p.sardine.ai. -> apicustomdomain.sardine.ai.
```

Interpretation

- p.money.x.com/healthz reachable — returns 200
- Sensitive file paths all 404
- API/webhook roots 403 behind Cloudflare
- No access-control-allow-origin header observed
- CNAMEs → Sardine infrastructure (third-party fintech, not a vulnerability)

[02] Secondary Health / Info Probing

Command

```
for path in "/metrics" "/version" "/api/v1/health" "/status" "/env"; do

curl -ks -o /dev/null -w "%{http_code}" \

"https://p.money.x.com$path"

done
```

Output

```
/metrics -> Denied/Not Found

/version -> Denied/Not Found

/api/v1/health -> Denied/Not Found

/status -> Denied/Not Found

/env -> Denied/Not Found
```

Interpretation

- No additional health/info/debug endpoints exposed from this set.

[03] Method / Host Header / Traversal Probes

Command

```
for target in p.money.x.com/healthz p.money.x.com api.money.x.com; do  
  
curl -k -X OPTIONS -I "https://$target" | grep -E "HTTP/|Allow"  
  
curl -k -I -H "Host: localhost" "https://$target" | grep "HTTP/"  
  
curl -k -I "https://$target/..%2f..%2fetc%2fpasswd" | grep "HTTP/"  
  
done
```

Output

```
--- p.money.x.com/healthz ---  
  
[Method] HTTP/2 200  
  
[Host-Local] HTTP/2 200  
  
[Traversal] HTTP/2 404  
  
--- p.money.x.com ---  
  
[Method] HTTP/2 404  
  
[Host-Local] HTTP/2 404  
  
[Traversal] HTTP/2 404  
  
--- api.money.x.com ---  
  
[Method] HTTP/2 403  
  
[Host-Local] HTTP/2 403  
  
[Traversal] HTTP/2 400
```

Interpretation

- OPTIONS 200 on /healthz — not a security issue alone
 - Host: localhost did not yield privileged response
 - Traversal probes: 404 / 400 — no bypass
-

[04] Variant Subdomain & Backup Access

Command

```
for sub in dev-p staging-p internal-api test-p admin; do  
  
dig +short "$sub.money.x.com"  
  
done  
  
curl -kI "https://p.money.x.com/%252e%252e%252f..%252fTrinity.txt.bak"  
  
curl -ks "https://p.money.x.com/metrics" | grep -i "go_info" | head -5
```

Output

```
dev-p.money.x.com -> (empty)  
  
staging-p.money.x.com -> (empty)
```

```
internal-api.money.x.com -> (empty)

test-p.money.x.com -> (empty)

admin.money.x.com -> 199.16.156.66

HTTP/2 404 (double-encoded backup path)

(no Prometheus go_info output)
```

Interpretation

- admin.money.x.com resolves to 199.16.156.66
- Double-encoded backup path → 404
- No Prometheus metric leak

[05] File/Debug Path Strikes

Command

```
for payload in "/Trinity.txt.bak" "/nice%20ports,/Trinity.txt.bak" \  
"/%2e%2e%2fTrinity.txt.bak" "../;/Trinity.txt.bak"; do  
curl -k -s -o /dev/null -w "%{http_code}" "https://p.money.x.com$payload"  
done  
  
for dbg in "/debug/requests" "/debug/pprof/heap" "/debug/pprof/goroutine"; do  
curl -k -s -o /dev/null -w "%{http_code}" "https://p.money.x.com$dbg"  
done  
  
curl -kI "https://p.money.x.com/v1/setup" | grep "HTTP/"
```

Output

```
/Trinity.txt.bak -> 404  
  
/nice%20ports,/Trinity.txt.bak -> 404  
  
/%2e%2e%2fTrinity.txt.bak -> 404  
  
../;/Trinity.txt.bak -> 404  
  
  
/debug/requests -> 401  
  
/debug/pprof/heap -> 404  
  
/debug/pprof/goroutine -> 404  
  
  
/v1/setup -> HTTP/2 404
```

Interpretation

- No backup-file exposure
- /debug/requests exists but access-controlled (401)
- No pprof exposure

[06] Auth-Wrapper / Normalization Checks

Command

```
for path in /debug/requests /debug/events /debug/pprof /debug/vars; do

curl -kI -H "X-Forwarded-For: 127.0.0.1" -H "X-Real-IP: 127.0.0.1" \

"https://p.money.x.com$path" | grep "HTTP/"

curl -kI "https://p.money.x.com/.$path" | grep "HTTP/"

done

curl -kI "https://p.money.x.com/robots.txt"

curl -kI "https://p.money.x.com/sitemap.xml"
```

Output

```
/debug/requests spoofed: HTTP/2 401 dot-segment: HTTP/2 301

/debug/events spoofed: HTTP/2 401 dot-segment: HTTP/2 301

/debug/pprof spoofed: HTTP/2 404 dot-segment: HTTP/2 301

/debug/vars spoofed: HTTP/2 404 dot-segment: HTTP/2 301

robots.txt -> HTTP/2 404

sitemap.xml -> HTTP/2 404
```

Interpretation

- Spoofed localhost headers did not bypass access control
 - Dot-segment normalization → redirect only, no auth bypass
 - robots.txt and sitemap.xml not exposed
-

[07] Redirect-Following & Path Edge Cases

Command

```
for target in "../debug/requests" "../debug/events"; do

curl -kL -i -H "X-Forwarded-For: 127.0.0.1" -H "X-Real-IP: 127.0.0.1" \

-A "Mozilla/5.0 Firefox/115.0" \

"https://p.money.x.com$target" 2>&1 \

| grep -E "HTTP/|server|Set-Cookie" | head -10

done
```

Output

```
--- ../debug/requests --- HTTP/2 401

--- ../debug/events --- HTTP/2 401
```

Interpretation

— Normalization redirect following still resulted in 401 — no bypass demonstrated.

[08] Truncation / Pollution-Style Variants

Command

```
for p in "/debug/requests?" "/debug/requests%00" "/debug/requests/."; do
    curl -k -s -o /dev/null -w "%{http_code}" "https://p.money.x.com$p"
done
```

Output

```
/debug/requests? -> 401
/debug/requests%00 -> 404
/debug/requests/. -> 404
```

Interpretation

— No auth bypass or path confusion issue demonstrated.

[09] Sidecar Infrastructure Guesses

Command

```
for sub in pushgateway grafana argocd-internal; do
    curl -k -s -o /dev/null -w "%{http_code}" "https://$sub.money.x.com"
done
```

Output

```
pushgateway.money.x.com -> 000 (no response)
grafana.money.x.com -> 000 (no response)
argocd-internal.money.x.com -> 000 (no response)
```

Interpretation

— No reachable services from these names.

[10] Direct Network Check — admin.money.x.com

Command

```
sudo nmap -Pn -p 443 --reason --packet-trace admin.money.x.com
```

Output

```
Nmap scan report for admin.money.x.com (199.16.156.66)

HOST STATUS: up (received user-set)

PORT STATE SERVICE REASON
443/tcp filtered https no-response
```

Interpretation

- admin.money.x.com → 199.16.156.66
 - Port 443 filtered — no response
 - Does not support a direct origin bypass finding
-

[11] Focused Comparison Probe

Command

```
for host in p.money.x.com api.money.x.com webhooks.money.x.com; do

curl -ksI "https://$host" -H "Origin: https://example.com" \

| grep -Ei "HTTP/|server:|access-control|content-type"

for path in /health /healthz /status /version; do

code=$(curl -ks -o /dev/null -w "%{http_code}" "https://$host$path")

[ "$code" = "200" ] && echo " [+] $path -> 200"

done

curl -ks "https://$host/robots.txt" | head -5

done
```

Output

```
=== p.money.x.com ===

HTTP/2 404 content-type: text/plain

[+] /healthz -> 200

404 page not found

=== api.money.x.com ===

HTTP/2 403 server: cloudflare

=== webhooks.money.x.com ===

HTTP/2 403 server: cloudflare
```

Interpretation

- p.money.x.com: only /healthz returned 200 — robots.txt absent
 - api + webhooks remain fully Cloudflare-blocked
-

[12] Final Direct Health Comparison

Command

```
for h in p.money.x.com api.money.x.com webhooks.money.x.com; do

echo "=== $h ==="

curl -ks "https://$h/healthz" | head
```

done

Output

```
=== p.money.x.com ===

OK

=== api.money.x.com ===

<!DOCTYPE html><title>Attention Required! | Cloudflare</title>

=== webhooks.money.x.com ===

<!DOCTYPE html><title>Attention Required! | Cloudflare</title>
```

Interpretation

- Clearest behavioral split: p.money.x.com/healthz returns only OK
- api.money.x.com/healthz → Cloudflare challenge page
- webhooks.money.x.com/healthz → Cloudflare challenge page
- p.money.x.com is reachable for health checks but exposes no sensitive data

Findings Summary

Issue	Status	Evidence	Impact	Reportable
Exposed health endpoint	OBSERVED	p.money.x.com/healthz → 200 OK	Low to none	Not reportable alone
Debug endpoints (auth-gated)	OBSERVED	/debug/requests & /debug/events → 401	None demonstrated	Not reportable — no bypass
Sensitive file exposure	NOT OBSERVED	.env, database.sql, config.json all 404	None	No
Traversal / encoding bypass	NOT OBSERVED	Variants returned 404 / 400	None	No
Host header abuse	NOT OBSERVED	localhost headers no impact	None	No
CORS misconfiguration	NOT OBSERVED	No ACAO credential issue captured	None	No
Origin IP / WAF bypass	NOT OBSERVED	admin IP resolved; 443 filtered	None demonstrated	No

Overall Conclusion

VERDICT

Does not meet threshold for a worthwhile bug bounty submission.

A valid submission would require at least one of:

- ✗ Unauthorized access

- ✗ Sensitive data exposure
- ✗ Access control bypass
- ✗ Origin bypass
- ✗ Exploitable misconfiguration
- ✗ Clear security impact

One-Line Summary

p.money.x.com exposes a minimal **/healthz** endpoint returning **OK**; debug paths exist but are protected with **401**; api.money.x.com and webhooks.money.x.com are blocked by Cloudflare; no auth bypass, traversal, origin bypass, CORS issue, or sensitive data exposure was confirmed.